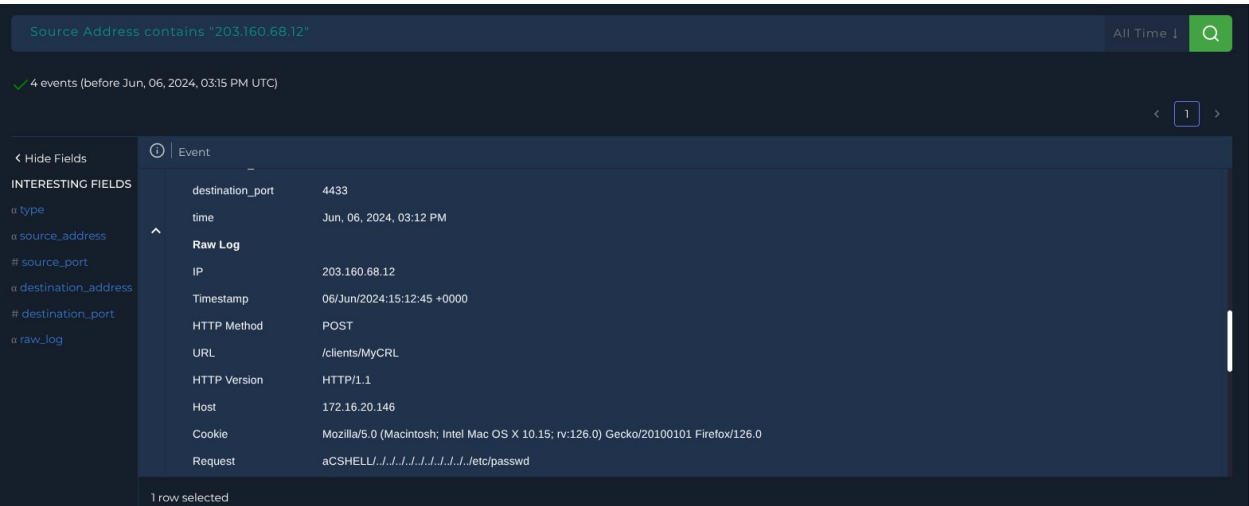


Event Information:

EventID :
263
Event Time :
Jun, 06, 2024, 03:12 PM
Rule :
SOC287 - Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]
Level :
Security Analyst
Hostname :
CP-Spark-Gateway-01
Destination IP Address :
172.16.20.146
Source IP Address :
203.160.68.12
HTTP Request Method :
POST
Requested URL :
172.16.20.146/clients/MyCRL
Request :
aCSHELL/../../../../../../../../etc/passwd
User-Agent :
Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:126.0) Gecko/20100101 Firefox/126.0
Alert Trigger Reason :
Characteristics exploit pattern Detected on Request, indicative exploitation of the CVE-2024-24919.
Device Action :
Allowed

Analysis Steps:

Logs were searched with IP 203[.]160.68.12 as the source and CP-Spark-Gateway-01 172[.]16.20.146 as the destination in the relevant time-frame yielding 4 events. The attacker can be seen attempting directory traversal on the endpoint.



There is no easily visible response codes that I can find after thoroughly investigating the logs. We can see that in the alert the device action is stated to be Allowed and as such this must be assumed to be successful.

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Chinese (Hong Kong) address associated with 203[.]160.68.12 AS 10099 (China Unicom Global). 6/91 security vendors flagged this IP address as malicious as of 2 days ago.

6

91

Community Score

6/91 security vendors flagged this IP address as malicious

203.160.68.12 [203.160.64.0/19]
AS 10099 (China Unicom Global)

HK Last Analysis Date
2 days ago

Reanalyze More

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Chong Lua Das	Malicious	CRDF	Malicious
CyRadar	Malicious	Forcepoint ThreatSeeker	Malicious
GreyNoise	Malicious	Webroot	Malicious
alphaMountain.ai	Suspicious	Abusix	Clean
Acronis	Clean	ADMINUSLabs	Clean

Do you want to automate checks?

On AbuseIPDB this IP was reported 2 times with a 0% confidence of abuse.

203.160.68.12 was found in our database!

This IP was reported 2 times. Confidence of Abuse is 0%?

0%

ISP	China Unicom (Hong Kong) Operations Limited
Usage Type	Data Center/Web Hosting/Transit
ASN	AS10099
Domain Name	chinabig.com
Country	Hong Kong
City	Hong Kong

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive exploit for an arbitrary file read vulnerability (CVE-2024-24919) targeting the Check Point Security Gateway host CP-Spark-Gateway-01 (172[.]16.20.146). An external threat actor bypassed security controls via directory traversal payloads, targeting sensitive system files including /etc/passwd and /etc/shadow.

Incident Details

- **Alert Name:** SOC287 - Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]
- **Target Host:** CP-Spark-Gateway-01 (172[.]16.20.146)
- **Attacker IP:** 203[.]160.68.12
- **Device Action:** Allowed

Analysis and Evidence

- **Attack Execution:** Log analysis revealed multiple HTTP POST requests targeting the /clients/MyCRL endpoint. The attacker used specific directory traversal patterns designed to exploit the gateway appliance directly.
- **Targeted Data:** Telemetry captures the threat actor attempting to read critical system files across multiple requests:
 - o At 03:12 PM: aCSHELL/../../../../../../../../etc/passwd
 - o At 03:14 PM: aCSHELL/../../../../../../../../etc/shadow

Threat Intelligence

- **OSINT (Infrastructure):** The attacking IP (203.160.68.12) is an external data centre address resolving to China Unicom Global (AS 10099) in Hong Kong.
- **Reputation:** VirusTotal confirms 6/91 security vendors flag this IP address as malicious. AbuseIPDB lists historical malicious scanning reports against this infrastructure.
- **Internal Correlation:** Internal correlation confirmed this was not part of an authorised penetration test or vulnerability scan.

Actions Taken

1. Analysed firewall connection logs, identifying active targeting of the CVE-2024-24919 path traversal flaw.
2. Traced the scope of the exploit to confirm requests for both public user indices (/etc/passwd) and encrypted password hashes (/etc/shadow).
3. Isolated the endpoint from the network.
4. Declared the alert a successful True Positive and escalated.

Let's Defend Result

SOC287 - Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]

True Positive (+5 Point)

Do You Need Tier 2 Escalation? (+5 Point)

Was the Attack Successful? (+5 Point)

What Is the Direction of Traffic? (+5 Point)

Check If It Is a Planned Test (+5 Point)

What Is The Attack Type? (+5 Point)

Is Traffic Malicious? (+5 Point)